Handoff 39: Dependabot for GitHub Actions (decision 31, SEC-08)

Date: 2026-11-02 (America/Toronto)
Written by: Claude Code (implementer), in a separate git worktree
For: the human maintainer, and ChatGPT or Claude chat (reviewer) without repository access
Status: **in_review**: one pull request (#44), not merged. A config file in the repository and one test.

> **How to use this file:** the pull request diff is the source of truth (`build.md` section 14).

Starter prompt for the chat assistant

```
You are checking a small Dependabot config for Python Academy. It should update
GitHub Actions only, monthly, and do nothing else. Check that it keeps the
pinned-commit format that backend/tests/test_ci_pins.py requires.
```

Run plan details

Field	Value
Stage	The second half of SEC-08, from the owner's decision 31
Base	`main`, at `1947f7a`. No other PR needs to merge first
Part 2 boxes relied on	**None**

1. Step 0

`git fetch --all`, `gh pr list --state all`. Worktree `../python-academy-depbot`; the main folder was not switched.

2. Handoff record (build.md template)

Field	Value
Task	Dependabot for GitHub Actions only, monthly
Non-goals	Updates for Python or npm packages; auto-merge; any GitHub setting

Field	Value
Data and compatibility	None
Deployment status	Not requested

Files changed

`.github/dependabot.yml` (new), `backend/tests/test_ci_pins.py` (1 new test), `docs/run-log.md`, this handoff and its PDF.

3. How it works

Once this merges, GitHub reads the file and checks monthly for newer versions of `actions/checkout`, `setup-python` and `setup-node`, opening at most 3 PRs. **It merges nothing.** No GitHub setting was changed by me. If no PR ever appears, check Insights → Dependency graph → Dependabot on GitHub, which is a page only you can see.

4. Decisions and why

Decision	Options considered	Reason	Who decided
GitHub Actions only, monthly		Decision 31	Owner
At most 3 open PRs	The default of 5	There are only three actions	Implementer

5. Bugs found and how they were fixed

None.

6. How it was tested

The file parses as YAML. `test_ci_pins.py`: 4 passed. The test checks the ecosystem and interval, so a later edit can't quietly widen it. **What this does not prove:** that Dependabot runs. Only GitHub can show that, after the merge. **Not checked:** whether its PRs keep the `# v4` comment format that the pin test requires. Dependabot normally updates such comments, and if one doesn't fit, that PR's own CI will fail and show it.

Deliberate break (each undone)	Tests that failed
B1. Add `npm` as a second ecosystem	**1**
B2. Change the interval to weekly	**1**

Deliberate break (each undone)	Tests that failed
B3. Delete the file	**1**

7. Known limitations

Security fixes in actions can wait up to a month. That is the choice made.

8. Live checks for you

Within about a month, see whether a Dependabot PR has appeared, or whether the page in section 3 shows a check.

9. Questions for you

None.

10. For the docs sync

Where	What
Stage table	"39. SEC-08 | Dependabot for GitHub Actions | in_review (#44, handoff 39)"

11. Next concrete action

Review and merge.

12. Removing the worktree safely

From the **main** folder, after this PR is merged:

```
cd /Users/DEV/Projects/python-academy
git -C ../python-academy-depbot status --short   # expect nothing
git worktree remove ../python-academy-depbot     # deletes only that folder; refuses if
anything is uncommitted
git worktree prune
git branch -d sec/dependabot-actions             # refuses if the branch is not merged
```

Don't delete the folder in the Finder or with `rm -rf`; Git would keep a stale record of it (`git worktree prune` fixes that).